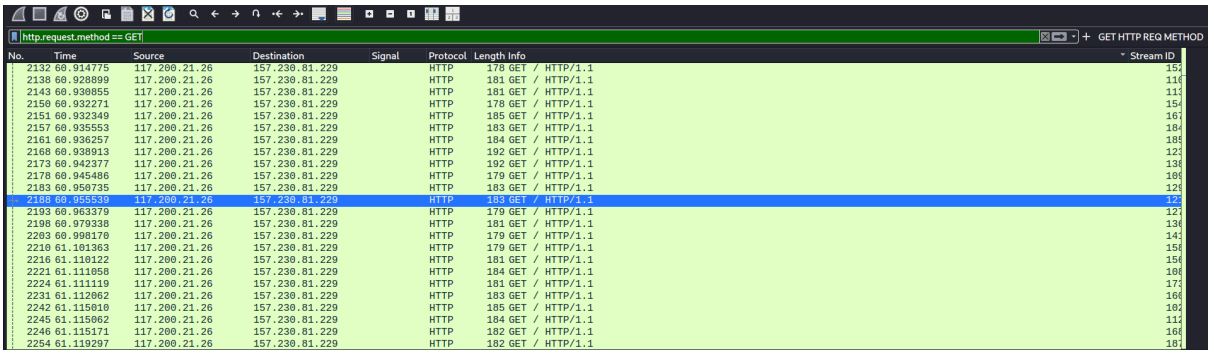
Rafael Angelo Christianto

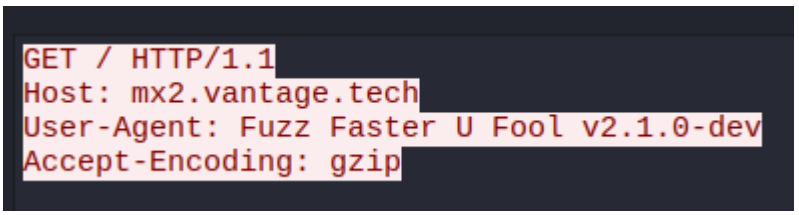
HACK THE BOX SHERLOCK

VANTAGE

1. What tool did the attacker use to fuzz the web server ? (Format- include version e.g, nmap@7.80)

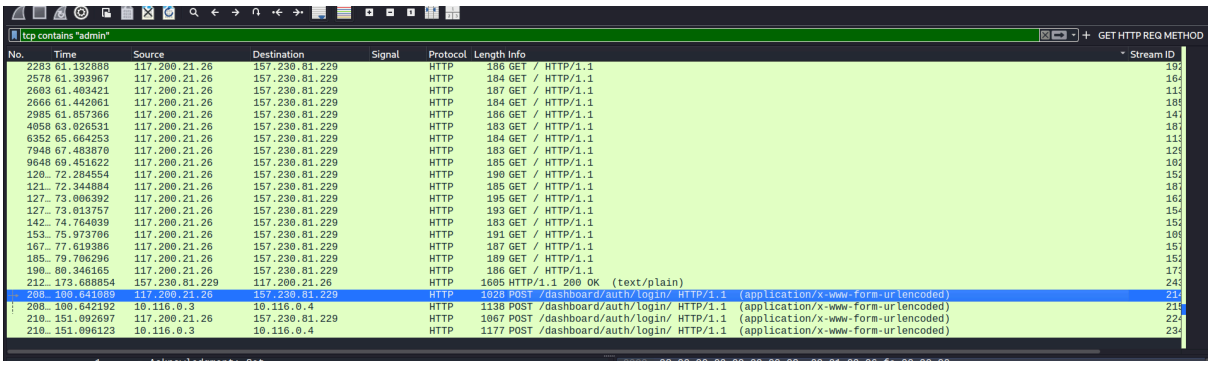


To solve this question, I just filtered all the GET requests and pick 1 of the packets to Follow TCP Stream



We can see the User-Agent, so the answer is **ffuf@2.1.0**

2. Which subdomain did the attacker discover?

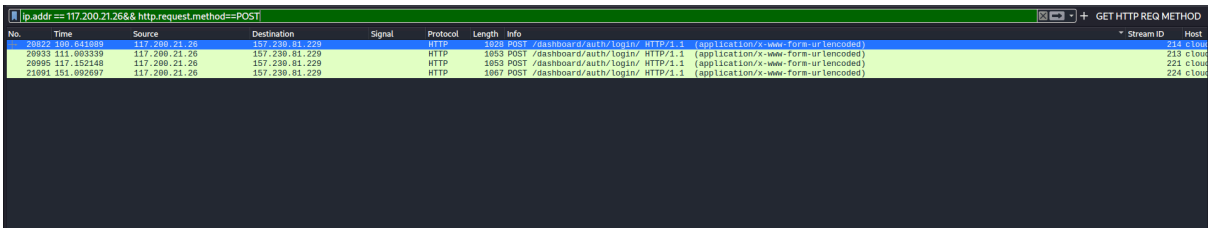


For this one, I tried to do tcp contains “admin”, just to see what comes out. And I found a POST request after a successful GET request and after following its TCP Stream.

```
POST /dashboard/auth/login/ HTTP/1.1
Host: cloud.vantage.tech
Connection: keep-alive
```

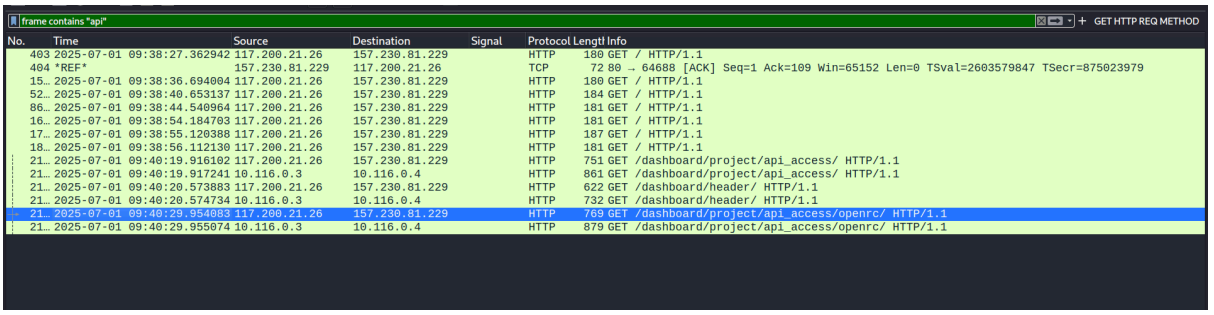
There we can see **cloud.vantage.com**

3. How many login attempts did the attacker make before successfully logging in to the dashboard?



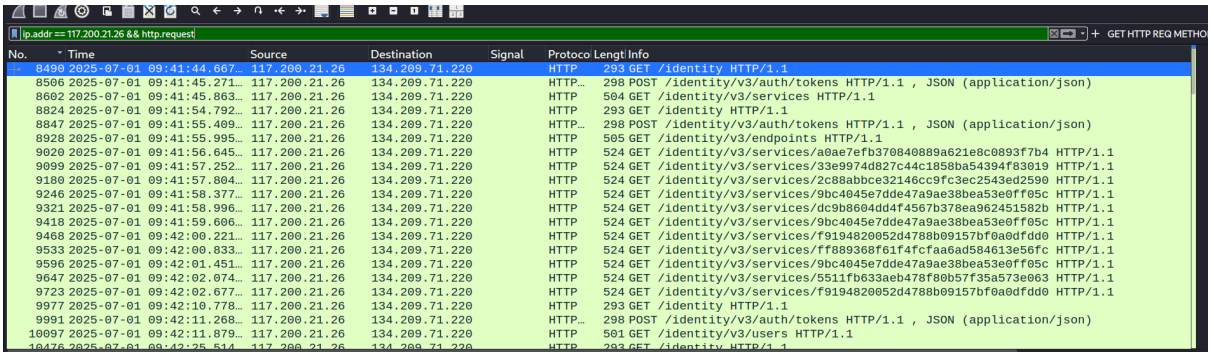
Even though we can see 4 packets, the question asked login attempts before successfully login. And also, when we follow TCP Stream, there are only **3**.

4. When did the attacker download the OpenStack API remote access config file? (UTC)



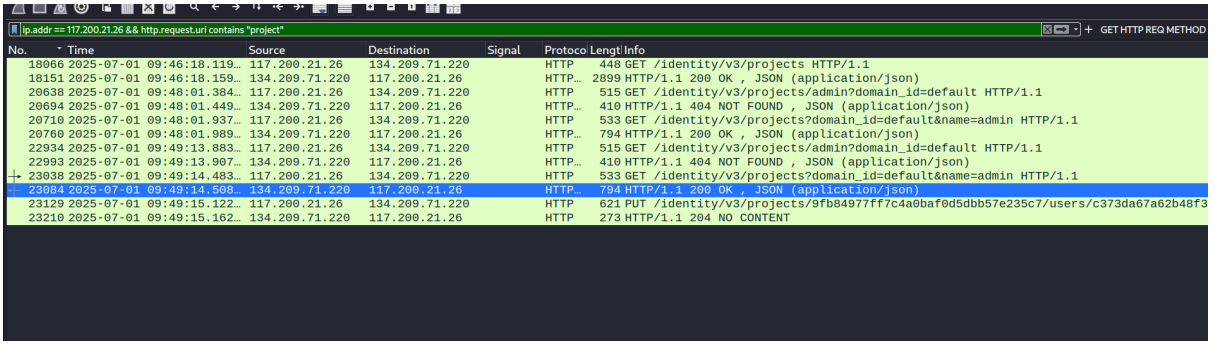
As highlighted blue on the screenshot above, the correct answer is **2025-07-01 09:40:29**, it is not 2025-07-01 09:40:19 since that was the time the page got loaded

5. When did the attacker first interact with the API on controller node? (UTC)



I filtered with the attacker's IP (117.200.21.26) AND http.request, and I input the first frame UTC time, which is **2025-07-01 09:41:44**.

6. What is the project id of the default project accessed by the attacker?



I filtered again with the attacker's IP and the http request URL containing the string "project", in order to find the project ID. And I found a successful HTTP request and I followed its TCP Stream.

In here, we can find the project ID, which is **9fb84977ff7c4a0baf0d5dbb57e235c7**

7. Which OpenStack service provides authentication and authorization for the OpenStack API?

Rafael Angelo Christianto

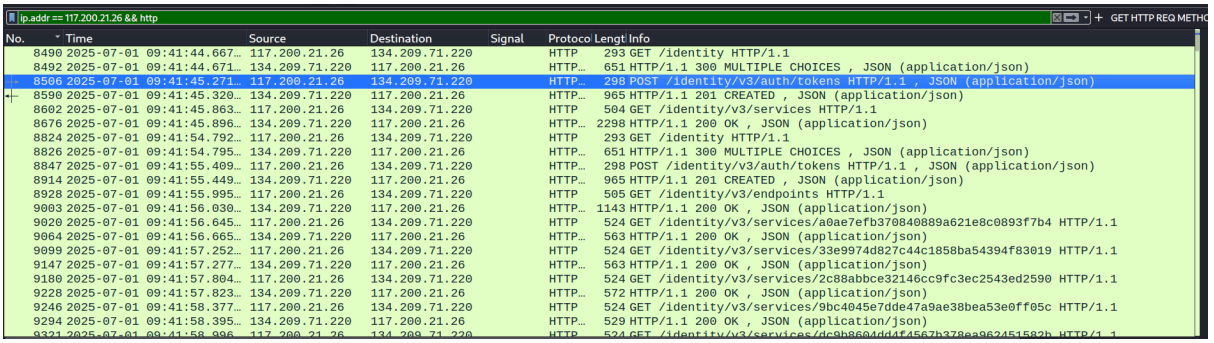
The OpenStack service that provides authentication and authorization for the OpenStack API is **Keystone**, also known as the OpenStack Identity service.

Keystone is a critical component of any OpenStack deployment and performs several key functions: Boer Technology +1

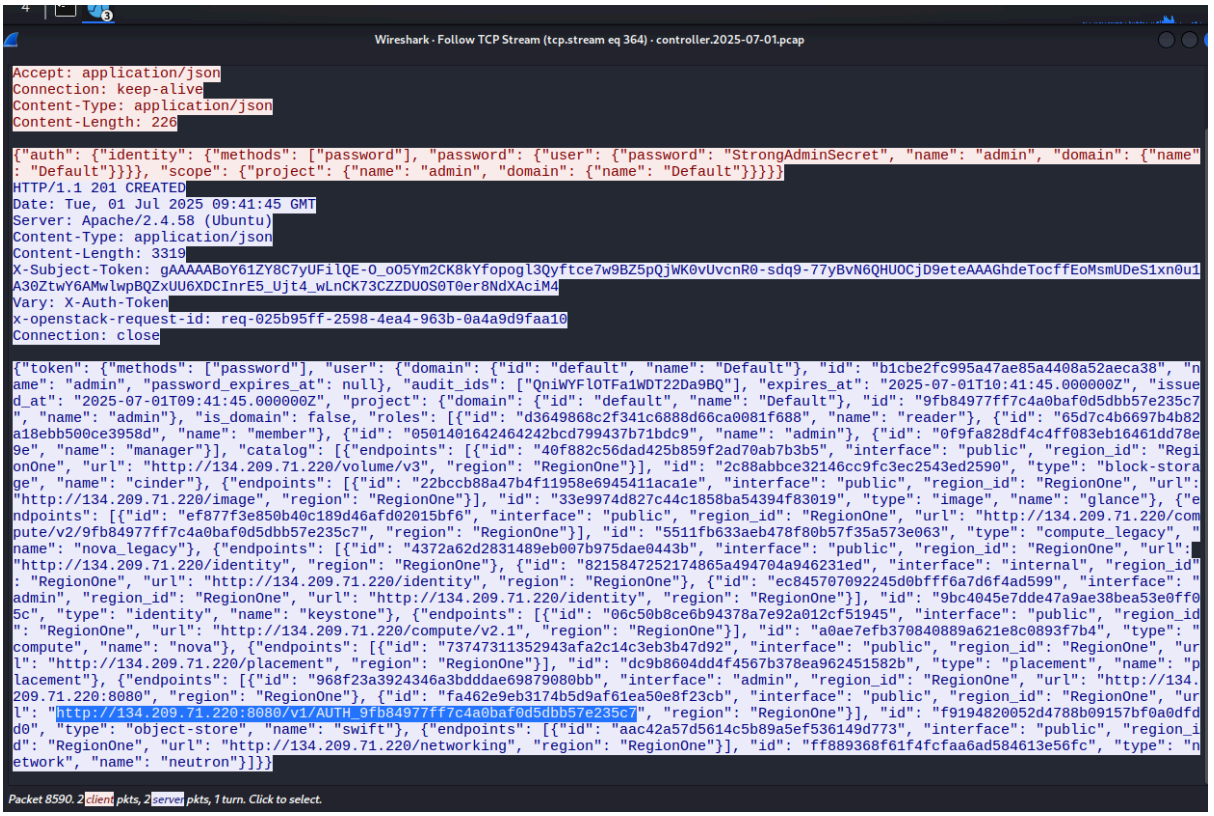
- **Authentication**: It verifies user credentials (like username/password, token, or federated identity via LDAP, SAML, or OpenID Connect).
- **Authorization**: It determines which resources and actions a user is permitted to access by leveraging policies and role-based access control (RBAC).

The answer to this question can be googled. The answer is **Keystone**.

8. What is the endpoint URL of the swift service?



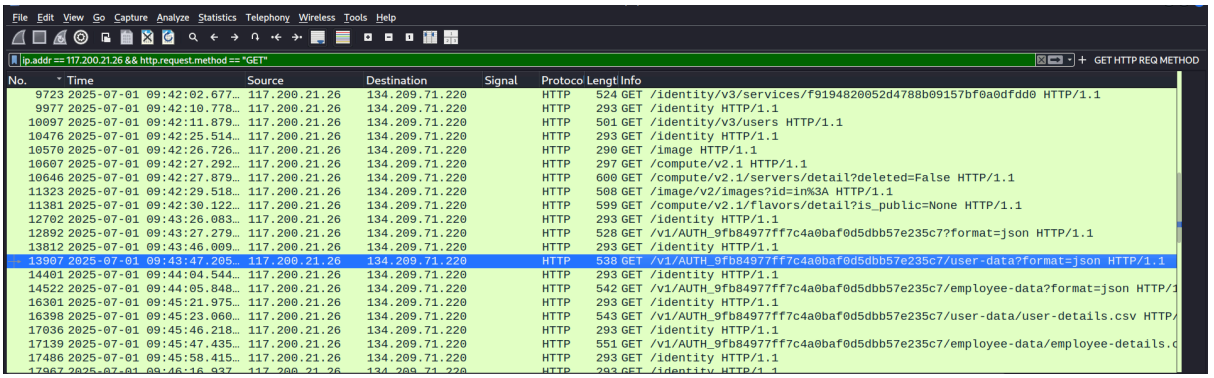
From the screenshot above, we see that there is the keyword /auth/tokens. So from there, I decided to follow TCP Stream.



There we can see the URL to the swift service given below, and that is the answer:

http://134.209.71.220:8080/v1/AUTH_9fb84977ff7c4a0baf0d5dbb57e235c7

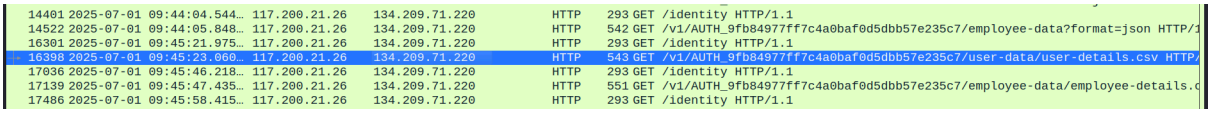
9. How many containers were discovered by the attacker?



For question number 9, I also filtered by the attacker's IP and use the GET HTTP request filter. There I find /v1/AUTH_9f.., and I followed its TCP Stream.

There, we can see the container count which is **3**.

10. How many user records are in the sensitive user data file?



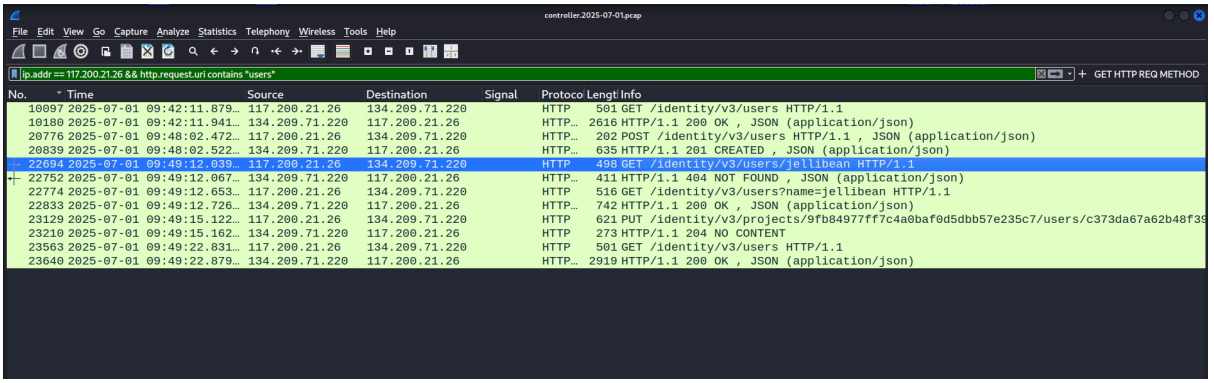
Still using the same filter from question 9, I saw the file “user-details.csv” and I input the UTC time which is **2025-07-01 09:45:23**, and that was the correct answer.

11. How many user records are in the sensitive user data file?

```
Full Name,Email,Phone Number
John Doe,john.doe@example.com,(123) 456-7890
Jane Smith,jane.smith@example.com,(234) 567-8901
Alice Johnson,a.johnson@example.com,(345) 678-9012
Bob Brown,b.brown@example.com,(456) 789-0123
Charlie Davis,c.davis@example.com,(567) 890-1234
Diana Wilson,d.wilson@example.com,(678) 901-2345
Ethan Moore,e.moore@example.com,(789) 012-3456
Fiona Taylor,f.taylor@example.com,(890) 123-4567
George Wilson,g.wilson@example.com,(901) 234-5678
Helen Adams,h.adams@example.com,(012) 345-6789
Ian Lee,i.lee@example.com,(123) 456-7890
Julia Smith,j.smith@example.com,(234) 567-8901
Kevin Miller,k.miller@example.com,(345) 678-9012
Laura Evans,l.evans@example.com,(456) 789-0123
Michael Thomas,m.thomas@example.com,(567) 890-1234
Natalie Wilson,n.wilson@example.com,(678) 901-2345
Oliver Johnson,o.johnson@example.com,(789) 012-3456
Penny Davis,p.davis@example.com,(890) 123-4567
Quinn Lee,q.lee@example.com,(901) 234-5678
Rachel Moore,r.moore@example.com,(012) 345-6789
Simon Evans,s.evans@example.com,(123) 456-7890
Tara Wilson,t.wilson@example.com,(234) 567-8901
Uma Johnson,u.johnson@example.com,(345) 678-9012
Vivian Lee,v.lee@example.com,(456) 789-0123
William Thomas,w.thomas@example.com,(567) 890-1234
Xander Wilson,x.wilson@example.com,(678) 901-2345
Yara Johnson,y.johnson@example.com,(789) 012-3456
Zoe Lee,z.lee@example.com,(890) 123-4567
```

Still continuing from number 10, from the same packet. I just Follow TCP Stream, and then I saw this data information about people, and the total was **28**.

12. For persistence, the attacker created a new user with admin privileges. What is the username of the new user?



Here in the screenshot, specifically on the packet I highlighted blue. We can see the username of the new user. And if we Follow TCP Stream the

packet right above it (22694), we can see the JSON to create the new user, like shown below:

```
POST /identity/v3/users HTTP/1.1
Host: 134.209.71.220
User-Agent: openstacksdk/4.6.0 keystoneauth1/5.11.1 python-requests/2.32.4 CPython/3.13.5
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
X-Auth-Token: gAAAAABoY67QSl3AarKC9p_FCUhm-zdlkNPcgfqpHncXtnKqPhHgH79XnHa-4IrDf4WlL8QpLiKIQOE8C4kq3Tv21nkTpzMAuGXwLZkEeexqQlLfUtyrhmGjKsF
vflRlIEZb0A-1oQZLVzdk1021QkPqjVjFonIEIEBgH0oZll7xE2hp7Scnm2o
Content-Type: application/json
Content-Length: 130

{"user": {"password": "P@$$word", "enabled": true, "default_project_id": "9fb84977ff7c4a0baf0d5dbb57e235c7", "name": "jellibean"}}
HTTP/1.1 201 CREATED
Date: Tue, 01 Jul 2025 09:48:02 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Type: application/json
Content-Length: 312
Vary: X-Auth-Token
x-openstack-request-id: req-70234e40-c6b0-4192-b478-e5cd3732d419
Connection: close

{"user": {"id": "c373da67a62b48f393c45dc071fa80b8", "name": "jellibean", "domain_id": "default", "enabled": true, "default_project_id": "
9fb84977ff7c4a0baf0d5dbb57e235c7", "password_expires_at": null, "options": {}, "links": {"self": "http://134.209.71.220/identity/v3/users
/c373da67a62b48f393c45dc071fa80b8"}}}
```

13. What is the password of the new user?

    Seen from the same screenshot right before this question the answer is **P@$$word**.

14. What is MITRE tactic id of the technique in task 12?

Under the Persistence tactic, we can see at the most bottom of the screenshot above “Create Account” technique, and there are 3 other subtechniques. And Create Account’s code is T1136

From the screenshot below, we see that there are only 3 options: local, domain, or cloud

Create Account

Sub-techniques (3)

ID	Name
T1136.001	Local Account
T1136.002	Domain Account
T1136.003	Cloud Account

Clicking on the Cloud Account subtechniques we can see it is to maintain access to victim systems and can be used to stay and have access after initial access.

It is not Local nor Domain account, since it is using a cloud service, which is OpenStack, specifically Keystone

Create Account: Cloud Account

Other sub-techniques of Create Account (3)

Adversaries may create a cloud account to maintain access to victim systems. With a sufficient level of access, such accounts may be used to establish secondary credentialed access that does not require persistent remote access tools to be deployed on the system.[1][2][3][4][5]

In addition to user accounts, cloud accounts may be associated with services. Cloud providers handle the concept of service accounts in different ways. In Azure, service accounts include service principals and managed identities, which can be linked to various resources such as OAuth applications, serverless functions, and virtual machines in order to grant those resources permissions to perform various activities in the environment.[6] In GCP, service accounts can also be linked to specific resources, as well as be impersonated by other accounts for Temporary Elevated Cloud Access.[7] While AWS has no specific concept of service accounts, resources can be directly granted permission to assume roles.[8][9]

Adversaries may create accounts that only have access to specific cloud services, which can reduce the chance of detection.

Once an adversary has created a cloud account, they can then manipulate that account to ensure persistence and allow access to additional resources - for example, by adding Additional Cloud

So the final answer is the Create Account-Cloud Account for the MITRE ATT&CK, which is **T1136.003**.